

Brought to you by:
ATTACKIQ

Cloud Security with MITRE ATT&CK®

**for
dummies**®
A Wiley Brand

Implement ATT&CK
for cloud cybersecurity

Execute a cloud-based
threat-informed defense

Optimize your
cybersecurity program



Jonathan Reiber
Lawrence C. Miller
Ben Opel

AttackIQ Special Edition

About AttackIQ

AttackIQ, the leading independent vendor of breach and attack simulation solutions, built the industry's first Security Optimization Platform for continuous security control validation and improving security program effectiveness and efficiency. AttackIQ is trusted by leading organizations worldwide to plan security improvements and verify that cyberdefenses work as expected, aligned with the MITRE ATT&CK framework. The Company is committed to giving back to the cybersecurity community through its free award-winning AttackIQ Academy (academy.attackiq.com), open Preactive Security Exchange, and partnership with MITRE Engenuity's Center for Threat-Informed Defense (ctid.mitre-engenuity.org).

About the Authors

Jonathan Reiber is Senior Director for Cybersecurity Strategy at AttackIQ and former Chief Strategy Officer for Cyber Policy in the U.S. Defense Department. **Lawrence C. Miller** has worked in IT in various industries for more than 25 years. He's written over 150 *For Dummies* books on numerous technology and security topics. **Ben Opel** is Senior Director for Customer Success at AttackIQ and a former captain in the United States Marine Corps.



Cloud Security with MITRE ATT&CK[®]

AttackIQ Special Edition

**by Jonathan Reiber,
Lawrence C. Miller,
and Ben Opel**

**for
dummies[®]**
A Wiley Brand

Cloud Security with MITRE ATT&CK® For Dummies®, AttackIQ Special Edition

Published by
John Wiley & Sons, Inc.
111 River St.
Hoboken, NJ 07030-5774
www.wiley.com

Copyright © 2022 by John Wiley & Sons, Inc.

No part of this publication may be reproduced, stored in a retrieval system or transmitted in any form or by any means, electronic, mechanical, photocopying, recording, scanning or otherwise, except as permitted under Sections 107 or 108 of the 1976 United States Copyright Act, without the prior written permission of the Publisher. Requests to the Publisher for permission should be addressed to the Permissions Department, John Wiley & Sons, Inc., 111 River Street, Hoboken, NJ 07030, (201) 748-6011, fax (201) 748-6008, or online at <http://www.wiley.com/go/permissions>.

Trademarks: Wiley, For Dummies, the Dummies Man logo, The Dummies Way, Dummies.com, Making Everything Easier, and related trade dress are trademarks or registered trademarks of John Wiley & Sons, Inc. and/or its affiliates in the United States and other countries, and may not be used without written permission. AttackIQ and the AttackIQ logo are trademarks or registered trademarks of AttackIQ or its subsidiaries in the United States and other countries. All other trademarks are the property of their respective owners. John Wiley & Sons, Inc., is not associated with any product or vendor mentioned in this book.

LIMIT OF LIABILITY/DISCLAIMER OF WARRANTY: WHILE THE PUBLISHER AND AUTHORS HAVE USED THEIR BEST EFFORTS IN PREPARING THIS WORK, THEY MAKE NO REPRESENTATIONS OR WARRANTIES WITH RESPECT TO THE ACCURACY OR COMPLETENESS OF THE CONTENTS OF THIS WORK AND SPECIFICALLY DISCLAIM ALL WARRANTIES, INCLUDING WITHOUT LIMITATION ANY IMPLIED WARRANTIES OF MERCHANTABILITY OR FITNESS FOR A PARTICULAR PURPOSE. NO WARRANTY MAY BE CREATED OR EXTENDED BY SALES REPRESENTATIVES, WRITTEN SALES MATERIALS OR PROMOTIONAL STATEMENTS FOR THIS WORK. THE FACT THAT AN ORGANIZATION, WEBSITE, OR PRODUCT IS REFERRED TO IN THIS WORK AS A CITATION AND/OR POTENTIAL SOURCE OF FURTHER INFORMATION DOES NOT MEAN THAT THE PUBLISHER AND AUTHORS ENDORSE THE INFORMATION OR SERVICES THE ORGANIZATION, WEBSITE, OR PRODUCT MAY PROVIDE OR RECOMMENDATIONS IT MAY MAKE. THIS WORK IS SOLD WITH THE UNDERSTANDING THAT THE PUBLISHER IS NOT ENGAGED IN RENDERING PROFESSIONAL SERVICES. THE ADVICE AND STRATEGIES CONTAINED HEREIN MAY NOT BE SUITABLE FOR YOUR SITUATION. YOU SHOULD CONSULT WITH A SPECIALIST WHERE APPROPRIATE. FURTHER, READERS SHOULD BE AWARE THAT WEBSITES LISTED IN THIS WORK MAY HAVE CHANGED OR DISAPPEARED BETWEEN WHEN THIS WORK WAS WRITTEN AND WHEN IT IS READ. NEITHER THE PUBLISHER NOR AUTHORS SHALL BE LIABLE FOR ANY LOSS OF PROFIT OR ANY OTHER COMMERCIAL DAMAGES, INCLUDING BUT NOT LIMITED TO SPECIAL, INCIDENTAL, CONSEQUENTIAL, OR OTHER DAMAGES.

For general information on our other products and services, or how to create a custom *For Dummies* book for your business or organization, please contact our Business Development Department in the U.S. at 877-409-4177, contact info@dummies.biz, or visit www.wiley.com/go/custompub. For information about licensing the *For Dummies* brand for products or services, contact BrandedRights&Licenses@Wiley.com.

ISBN: 978-1-119-87546-8 (pbk); ISBN: 978-1-119-87547-5 (ebk) Some blank pages in the print version may not be included in the ePDF version.

Publisher's Acknowledgments

Some of the people who helped bring this book to market include the following:

Project Manager:

Carrie Burchfield-Leighton

Acquisitions Editor: Ashley Coffey

Sr. Managing Editor: Rev Mengle

Business Development

Representative: Molly Daugherty

Table of Contents

FOREWORD	V
INTRODUCTION	1
About This Book	1
Foolish Assumptions	1
Icons Used in This Book	2
Beyond the Book	2
CHAPTER 1: Implementing a Threat-Informed Defense for Cloud	3
Recognizing Cloud Security Challenges	3
ATT&CK 101	6
Mapping Threats to Native Cloud Controls	7
Azure	8
AWS	9
CHAPTER 2: Developing an Ongoing Program of Threat-Informed Defense	11
Scoring Cloud Security Effectiveness	11
Exploring ATT&CK Cloud Security Use Cases	13
Determine the technique coverage of a control	14
Select controls to mitigate a specific set of techniques	14
Determine which controls can defend against a given group	15
CHAPTER 3: Leveraging ATT&CK at Microsoft and Google	17
Enriching Threat Intelligence and Security Controls at Microsoft	17
Transforming Cloud Security at Google	19
CHAPTER 4: Ten Lessons for Cloud Security Operations	21
Know Your (Shared) Responsibilities	21
Understand Your Data and Use Case	22
Know Your Terrain — Cloud Architecture Can Be Strange and Confusing	22

Know Your Controls — Cloud Security Is a Little Odd	23
Drain the Moat — Perimeter-Based Models Are Largely Obsolete.....	23
Treat Identity As the New Data.....	23
Treat Data As the New Identity.....	24
Address Datastore Considerations	24
Be Neighborly in Multi-Tenant Environments	24
“There Is No Cloud” — It’s Just Someone Else’s Datacenter	25

Foreword

In the span of nearly 40 years, the internet spread from zero users to over 4.3 billion globally. It has altered everything. From banking to military operations to how people share ideas. Yet there was a twist: Internet access increased without a commensurate understanding of risk. Now hostile actors can strike from afar to disrupt data, impact critical infrastructure operations, and, perhaps most importantly, alter our perceptions of reality. The pace of change shows no sign of slowing down.

The movement to the cloud is an important sub-plot in the broader cybersecurity narrative, and that's why this book is focused on cloud security, the MITRE ATT&CK framework, and threat-informed defense. For years, the internet worked mostly through infrastructure based on local hardware: local hard drives, local hosts, local data centers. But as Iman Ghanizada of Google Cloud says in Chapter 4 of this book, the advent of cloud technologies has changed everything about how the internet is built and operated. With the cloud, infrastructure, policy, and configuration can all now exist as code. What are some of the benefits? Cloud technologies can be deployed quickly, updates and integrations can occur automatically, cloud services can scale rapidly, allow for collaboration across geographies, and they can facilitate data back-up and restoration, among other benefits.

What do these innovations mean for threat-management? How can you improve your security effectiveness in the cloud universe? Enter the MITRE ATT&CK framework and the practice of threat-informed defense. First published in 2015 by the MITRE Corporation, a federally funded research and development organization operating in the public interest, MITRE ATT&CK provides a kind of periodic table of adversary tactics, techniques, and common knowledge (A.T.T.&C.K.) for defenders to use to test their defenses against potential cyberattacks. Prior to the publication of ATT&CK, defenders lacked an unclassified, simple means for describing adversary behaviors and validating their defenses against known threats. With the advent of ATT&CK, teams can turn around and test their security controls through an automated breach and attack simulation platform and a “purple team” construct to validate their security program effectiveness.

Recognizing the transformative power of ATT&CK in cybersecurity, in 2020 a group of leading cybersecurity professionals created the Center for Threat-Informed Defense (the Center), a private research organization operated out of MITRE Engenuity to amplify the defensive opportunities that ATT&CK provides. After two years and more than 13 research projects behind it, the Center is at the forefront of a movement for applied research in cybersecurity operations. In late 2020, it published the “ATT&CK Cloud Mappings” project — aligning the threat behaviors in MITRE ATT&CK to the cloud security capabilities in Azure, AWS, and, soon, Google Cloud.

How does ATT&CK help? Cloud service providers have a range of “native cloud security controls” — security capabilities embedded within their services — that their customers can use to defend their data. By mapping the known threat tactics, techniques, and procedures (TTPs) in ATT&CK to native cloud security controls, security teams can gain a comprehensive picture of the threats that matter most to their organization and, more importantly, how well their cloud security controls perform against those threats. That is just one benefit. There are many more.

This book walks you through the applications of the mapping project and shows you how to make the most of your cloud security operations. It even includes a chapter on lessons for cloud security operations, drawn from the insights of Ben Opel, Senior Director for Customer Success at AttackIQ and a former captain in the United States Marine Corps. His ideas helped define the Marines Corps’ early cyberdefense doctrine for defending cloud and on-premises environments.

Life is in flux. Technology changes all the time, yet some things are constant. If you focus on the threats that matter most to your organizations, your societies, and your countries, your defenses will be far better prepared to confront top-tier threats when the time comes. I hope you find this book a guide on the practical steps to get there.

Jonathan Reiber

Senior Director for Cybersecurity Policy and Strategy, AttackIQ

Former Speechwriter and Chief Strategy Officer for Cyber Policy,
Office of the U.S. Secretary of Defense

Introduction

Cloud security is complex, and relatively few organizations today are able to effectively use the native security controls and tools available in public cloud platforms. Each cloud provider has different security offerings with various levels of maturity and effectiveness. Many security operations centers (SOCs) continue to struggle with the shift from on-premises to cloud security and are often unaware of the security options available within their Azure, Amazon Web Services (AWS), and/or Google Cloud Platform environments.

The MITRE Adversarial Tactics, Techniques, and Common Knowledge (ATT&CK) framework provides a clear, standardized method for organizations to address complexity in their cloud environments and increase their cloud cybersecurity effectiveness.

About This Book

Cloud Security with MITRE ATT&CK For Dummies, AttackIQ Special Edition, consists of four chapters that explore

- » How to get started with a threat-informed defense strategy for the cloud (Chapter 1)
- » Optimizing your cloud security strategy (Chapter 2)
- » Applying MITRE ATT&CK at Microsoft and Google (Chapter 3)
- » Ten lessons for cloud security operations (Chapter 4)

Each chapter is written to stand on its own, so if you see a topic that piques your interest feel free to jump ahead to that chapter. You can read this book in any order that suits you.

Foolish Assumptions

It's been said that most assumptions have outlived their usefulness, but we assume a few things nonetheless. Mainly, we assume that you're a chief information security officer (CISO), security analyst, cybersecurity professional, or red/blue/purple team engineer responsible for your organization's cloud security. As such,

this book is written primarily for technical readers with at least an understanding of security and cloud fundamentals.

If any of these assumptions describe you, then this is the book for you. If none of these assumptions describe you, keep reading anyway. You'll raise your IQ about cloud security and MITRE ATT&CK.

Icons Used in This Book

Throughout this book, we occasionally use special icons to call attention to important information. Here's what to expect:



REMEMBER

This icon points out important information you should commit to your nonvolatile memory, your gray matter, or your noggin.



TECHNICAL
STUFF

This icon explains the jargon beneath the jargon and is the stuff legends — well, legendary nerds — are made of.



TIP

Tips are appreciated, but never expected — and we sure hope you'll appreciate these useful nuggets of information.

Beyond the Book

There's only so much we can cover in this short book, so if you find yourself at the end of this book wondering, "Where can I learn more?", check out these additional resources:

- » The AttackIQ website (attackiq.com)
- » *The CISO's Guide to Better Vulnerability Management Using MITRE ATT&CK* (attackiq.com/lp/the-cisos-guide-to-better-vulnerability-management-using-mitre-attack-ty)
- » *Countering Ransomware with MITRE ATT&CK 101 Guide* (attackiq.com/lp/your-101-guide-to-countering-ransomware-with-mitre-attack)

- » Looking at complexity and shared responsibilities in the cloud
- » Learning the basics of the MITRE ATT&CK framework
- » Mapping the ATT&CK framework to Azure and AWS controls

Chapter 1

Implementing a Threat-Informed Defense for Cloud

In this chapter, you find out about the public cloud security challenges for security organizations. We also cover the basics of the MITRE Adversarial Tactics, Techniques, and Common Knowledge (ATT&CK) framework, and the Center for Threat-Informed Defense (the Center) methodology for mapping threats to Azure and Amazon Web Services (AWS) native security controls.

Recognizing Cloud Security Challenges



The velocity and scale of attacks targeting cloud platforms and resources is increasing at an alarming rate. In fact, according to a 2020 Help Net Security survey, 70 percent of organizations experienced a public cloud security incident and 96 percent of organizations were concerned about their level of cloud security. A separate survey found that 65 percent of IT leaders cited

“security and compliance risk” as the factor most likely to stymie their abilities to reach their cloud strategy goals. Likewise, the *Flexera 2021 State of the Cloud Report* found that cloud security is a top challenge for 81 percent of organizations.

It’s clear that cloud platform attacks are a top concern.

For security operations center (SOC) staff that has been equipped and trained to monitor and protect resources inside a network perimeter and on-premises data center, the evolving public cloud threat landscape is an entirely new challenge. The network edge isn’t easily defined or controlled in the public cloud and the demarcation between where the cloud service provider’s (CSP) security responsibilities end and the customer’s begin isn’t always well understood.

The shared responsibility model, shown in Figure 1-1, shows which elements the CSP is responsible for and which elements the enterprise customer is responsible for, depending on the service type — infrastructure as a service (IaaS), platform as a service (PaaS), or software as a service) — but in practice the shared responsibility model can be challenging to implement.

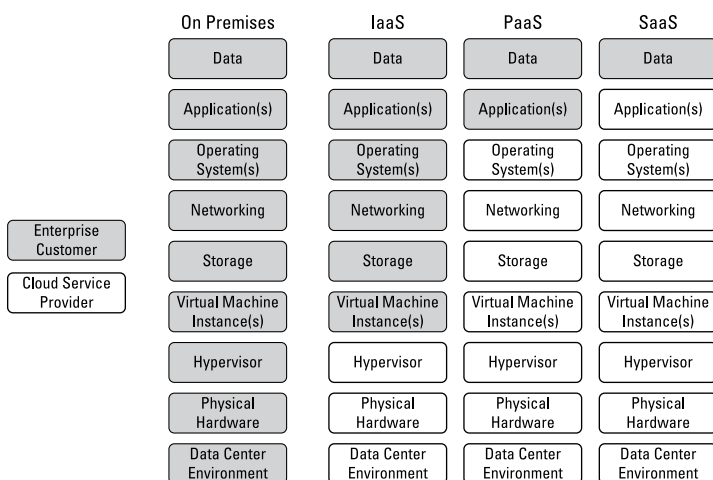


FIGURE 1-1: The shared responsibility model.

Generally speaking, the CSP — for example, Microsoft, Amazon, or Google — is responsible for the physical security of the cloud data center environment, physical hardware, and virtualization

layer (hypervisor), as well as keeping different customer environments logically isolated.

The customer is always responsible for the security and privacy of their data. Additionally, in an IaaS deployment the customer is basically responsible for everything in the stack above the hypervisor, as shown in Figure 1-1. In a PaaS environment, the CSP is responsible for the virtual machine instance, storage, networking, operating system (including updates and patching), and middleware (such as databases) and the customer is only responsible for the applications deployed in the PaaS offering and the associated data. In a SaaS deployment, the customer is only responsible for the data.

However, most organizations today typically run some combination of all three — IaaS, PaaS, and SaaS — so their responsibilities vary widely across the full spectrum of services. Additionally, most organizations — 92 percent of enterprises according to the *Flexera 2021 State of the Cloud Report* — have a multi-cloud strategy composed of more than five public and private clouds, but only 38 percent use multi-cloud security tools to protect their growing multi-cloud environments. This lack of multi-cloud security tools adds to the challenge for SOC teams because each CSP offers its own proprietary tools and services to manage its respective environments.



According to a report by the National Security Agency (NSA), while many CSPs provide cloud security configuration tools and monitoring systems, cloud customers are responsible for configuring the service themselves according to organizational security requirements. Specific responsibilities vary by CSP, by cloud service type, by specific product offering, and so on.

Finally, CSPs are maturing their platforms quickly and constantly introducing innovation and change. Keeping up with the pace of change is a real challenge and many customer SOC teams struggle to stay abreast of the different security capabilities and tools that are native to their different cloud environments. Some platforms include antivirus protection; others don't. Likewise, some cloud platforms have built-in firewalls, but many of their customers don't realize this capability exists or fully understand how to properly configure and effectively manage the technology offerings.



Organizations need to ensure that the settings and configurations of cloud-native protections offered by their CSP(s) adequately address their security, privacy, and compliance requirements.

ATT&CK 101

The MITRE Corporation's ATT&CK framework is an open global knowledgebase of the malicious activities observed in real-world cyberattacks. MITRE began developing the ATT&CK framework in 2013 to document common tactics, techniques, and procedures (TTPs) used by advanced persistent threat (APT) groups, and the framework was first published in 2015. Today, ATT&CK is composed of two matrices: Enterprise and Mobile. We focus on the Enterprise in this section.



The ATT&CK Matrix for Enterprise consists of 14 tactics and 218 techniques, defined by MITRE. *Tactics* explain the “why” of a technique (or sub-technique). *Techniques* explain “how” an adversary achieves its tactical objective. The 14 tactics are as follows:

- » **Reconnaissance:** The adversary gathers information to plan future actions against the target (10 techniques).
- » **Resource development:** The adversary establishes resources to support their actions against the target (7 techniques).
- » **Initial access:** The adversary breaches the target network (9 techniques).
- » **Execution:** The adversary installs malware and runs exploits in the target environment (12 techniques).
- » **Persistence:** The adversary establishes additional footholds in the target environment (19 techniques).
- » **Privilege escalation:** The adversary attempts to gain privileged access in the target environment (13 techniques).
- » **Defense evasion:** The adversary attempts to avoid detection in the target environment (40 techniques).
- » **Credential access:** The adversary creates or steals account names or passwords in the target environment (15 techniques).

- » **Discovery:** The adversary maps out the target environment (29 techniques).
- » **Lateral movement:** The adversary attempts to move freely within the target environment (9 techniques).
- » **Collection:** The adversary gathers data to achieve their objectives in the target environment (17 techniques).
- » **Command and control:** The adversary establishes communication with and takes control of compromised systems in the target environment (16 techniques).
- » **Exfiltration:** The adversary steals data in the target environment (9 techniques).
- » **Impact:** The adversary alters, disrupts, or destroys systems and data in the target environment (13 techniques).



TIP

MITRE regularly updates the number of tactics and techniques in its matrices, so these numbers can change over time. For more information, check out attack.mitre.org.

Mapping Threats to Native Cloud Controls

The Center is a non-profit, privately funded research and development organization operated by MITRE Engenuity. Working in partnership with leading cybersecurity experts and corporations from around the world (as you can see on its website — ctid.mitre-engenuity.org), the Center has developed a methodology that enables security teams to use the adversary behaviors described in ATT&CK to

- » Characterize the impact of Common Vulnerabilities and Exposures (CVEs) in their public cloud environments
- » Map ATT&CK to the CSP's native security controls to facilitate security control testing



TECHNICAL
STUFF

What is CVE? It's an international, community-based effort that maintains a community-driven, open data registry of publicly known cybersecurity vulnerabilities. CVE is operated by the MITRE Corporation, a not-for-profit organization which is funded by the U.S. Department of Homeland Security Cybersecurity and

Infrastructure Security Agency (CISA) Vulnerability Management Component.

The Center's methodology makes it possible for organizations to bridge vulnerability management, threat modeling, compensating controls, and security optimization to understand the risks associated with specific vulnerabilities in their public cloud environments and test their compensating controls against known threats. The Center is actively mapping known threat behaviors to the security controls native to each major public cloud platform. Each mapping consists of five steps:

1. Identify platform security controls.

Document specific security controls native to the public cloud platform.

2. Review security controls.

Collect and analyze documentation for each control and identify functionality that mitigates specific ATT&CK techniques and sub-techniques.

3. Identify mappable ATT&CK techniques and sub-techniques.

Align the appropriate ATT&CK security function category to the selected control, the type(s) of resources the control is designed to protect, and the ATT&CK TTPs that target those resources.

4. Produce score assessments.

Score the cloud control on its ability to detect, protect against, and respond to each of the identified TTPs.

5. Create mapping files.

Based on the assigned scores, map each TTP to the cloud control or controls best able to defend against it.

Azure

By drawing clear connections between Azure's native security capabilities and ATT&CK, the CTID methodology lays the foundation for organizational SOCs to understand the efficacy (or lack thereof) of their current cloud security configurations. In fact, simply seeing this delineation of Azure's current security capabilities helps security practitioners know what protections are available to them.

The Center's methodology maps Azure's native IaaS security controls to the ATT&CK framework. To date, the project has produced mappings for 48 Azure controls and 20 Azure control tags. The mapping includes controls such as

- » Advanced Threat Protection (ATP) for Azure SQL Database
- » Azure AD Identity Protection and Secure Score
- » Azure AD Multi-Factor Authentication (MFA) and Conditional Access (CA)
- » Azure Firewall
- » Azure Key Vault
- » Azure Sentinel
- » Docker Host Hardening
- » Just-in-Time (JIT) Virtual Machine (VM) Access
- » Network Security Groups (NSGs)
- » Role-Based Access Control (RBAC)



TIP

Find the full mapping at center-for-threat-informed-defense.github.io/security-stack-mappings/Azure/README.html.

AWS

The Center next undertook mapping AWS native controls to the ATT&CK framework. As with the Azure mappings, the project's AWS mappings enable security practitioners to make threat-informed decisions when selecting native security controls for their AWS environments.

The CTID methodology maps the native IaaS security controls in AWS to the ATT&CK framework. To date, the project has produced mappings for 29 AWS controls and 12 AWS control tags. The mapping includes controls such as

- » Amazon Cognito
- » Amazon Virtual Private Cloud (VPC)
- » AWS Certificate Manager
- » AWS CloudTrail and CloudWatch
- » AWS Directory Service
- » AWS Identity and Access Management (IAM)

- » AWS Key Management Service (KMS)
- » AWS Relational Database Service (RDS)
- » AWS Simple Storage Service (S3)
- » AWS Single Sign-On (SSO)



TIP

Find the full mapping at center-for-threat-informed-defense.github.io/security-stack-mappings/AWS/README.html.

- » Measuring cloud security effectiveness
- » Applying cloud security use cases

Chapter 2

Developing an Ongoing Program of Threat-Informed Defense

In this chapter, you learn about the Center for Threat-Informed Defense (the Center) scoring rubric for cloud security controls, different cloud security use cases, and the role of breach and attack simulation (BAS) in a threat-informed defense strategy.

Scoring Cloud Security Effectiveness

As part of its initiative to map public cloud security controls to the MITRE Adversarial Tactics, Techniques, and Common Knowledge (ATT&CK) framework, the Center has developed a scoring rubric to objectively measure the effectiveness of an individual security control against a specific threat. The scoring rubric provides the following score values:

- » **Minimal:** The control provides minimum mitigation of the ATT&CK technique (or sub-technique).

- » **Partial:** The control provides partial mitigation of the ATT&CK technique (or sub-technique).
- » **Significant:** The control provides significant mitigation of the ATT&CK technique (or sub-technique).

Additionally, the following factors are considered when assessing a control's mitigation capability:

- » **Coverage:** Assesses the control's ability to mitigate the described behavior of the technique (or sub-technique) based on real-world occurrences
- » **Temporal:** Assesses how frequently the control operates: real-time, periodic (minutes, hours, days), or triggered
- » **Accuracy:** Assesses the fidelity of a control's detection capability (for example, false positives and false negatives)

Finally, the scoring rubric assess the effectiveness of the security control in three categories:

» **Protect**

- Minimal: Low protect coverage factor regardless of other score factors
- Partial: Medium to high protect coverage factor; temporal factor of hours/days
- Significant: High protect coverage factor; real-time or near real-time (seconds, low minutes) temporal factor

» **Detect**

- Minimal: Low or uncertain detection coverage factor regardless of other score factors
- Partial: Medium to high detection coverage factor; temporal factor of hours/days; unknown or suboptimal accuracy and/or temporal factor
- Significant: High detection coverage factor; low false-positive/false-negative rates; real-time or near real-time (seconds, low minutes) temporal factor

» **Respond**

- Minimal: Data enrichment/forensics — the control provides data enrichment/forensics intended to aid an analyst in responding to the ATT&CK technique (or sub-technique). For example, label an event with ATT&CK details.

- **Partial:** Containment of an incident — the control contains the impact of the technique (or sub-technique) by preventing it from growing or impacting other systems; it minimizes the impact of an incident but requires additional mitigation action to be performed to completely mitigate the threat (for example, quarantine a file, disable an account).
- **Significant:** Eradication — it mitigates the threat by removing it (for example, force account password change, remove malware from storage, terminate process and delete executable).



TIP

Security operations centers (SOCs) can use the Center's threat map (we discuss this in Chapter 1) to determine how effective specific cloud-native tools are in protecting their organization against a specific ATT&CK technique or sub-technique. The security team should already understand which threats pose the greatest risk to their unique organization: those that are likely to be attempted and would have the highest impact if successful. Evaluating the ability of cloud-native solutions to detect, prevent, and respond to each of the tactics, techniques, and procedures (TTPs) most threatening to their business will indicate any significant gaps in the cloud platform's security coverage. Those gaps translate into security capabilities that the SOC should prioritize for investment in a third-party solution.

Seeing the TTPs against which specific cloud-native security tools provide the best protection also gives the security team valuable intelligence as they configure those tools. The mapping provides insights into which controls can effectively mitigate a specific set of TTPs. Because some techniques map to multiple controls, the security team may find that they can use different combinations of controls to mitigate one technique. The scoring rubric can support decisions about how to configure the available tools to minimize the number of controls while maximizing their impact.

Exploring ATT&CK Cloud Security Use Cases

The Center threat map supports many use cases to help organizations evaluate and improve the overall effectiveness of their cloud security programs and individual cloud-native security controls. You explore a few basic use cases in this section.

Determine the technique coverage of a control

With security controls mapped to individual techniques (or sub-techniques), determining the coverage of a control (or set of controls) is as simple as following the mappings from the control(s) to the associated techniques. Each mapping includes a scoring of the effectiveness of the control in mitigating the technique. Most scores also include comments which describe the rationale for a particular score so that you can tailor the score to your environment.

For example, a particular control that detects threats to a database-as-a-service (DBaaS) offering may be scored as a Minimal detection because its detection does not detect threats to databases installed on infrastructure-as-a-service (IaaS) components. But in your environment, you may only be using the DBaaS offering so you might consider adjusting the score of the control from Minimal to Partial (or Significant) to reflect the improved coverage with respect to your particular environment.

Select controls to mitigate a specific set of techniques

This use case is essentially the reverse of the use case described in the previous section. The Center threat mapping project includes an ATT&CK Navigator (available at mitre-attack.github.io/attack-navigator) that aggregates the ATT&CK coverage of all the controls mapped for the platform into a single layer. These layer files provide the reverse mapping of the information contained in a mapping file. Rather than mapping a control to the set of techniques (or sub-techniques) that it mitigates, it provides a mapping for each technique to the set of controls that mitigate it. You can use this layer file to search for the set of techniques and the corresponding controls that provide a mitigation.



TIP

Use the ATT&CK Navigator to visualize information about control coverage.

Because techniques can map to multiple controls, it is likely that there will be multiple combinations of controls which could mitigate the techniques. Given a way of ranking the possible solutions (for example, minimize the number of controls, maximize the baseline-impact of controls) a dynamic programming algorithm can be implemented to determine the optimal set of controls required to mitigate the techniques.

Determine which controls can defend against a given group

Threat actor groups and malicious software in ATT&CK are mapped to techniques. Therefore, this use case can be achieved by reviewing the set of techniques (or sub-techniques) that are associated with the group or software of interest and then exploring the set of security controls that mitigate those techniques. This use case then becomes an extension of the use case described in the previous section, where the set of techniques is associated with the group or software of interest.



TIP

Additional use cases include determining which controls the SOC should use to implement a particular ATT&CK mitigation, and which controls to use to defend against a threat group or attack method that is cause for high concern. A security analyst who hears about an emerging threat may turn to the rubric and see that the controls currently in place can detect, but not prevent, that type of attack. The fact that the security team recognizes their required role in responding to a specific emerging threat can accelerate their response by an order of magnitude, compared with a team that assumes their cloud security platform will prevent the attack.

OPTIMIZING CLOUD SECURITY EFFECTIVENESS WITH A BAS PLATFORM

Breach and attack simulation (BAS) is the process of using software to emulate adversary tactics, techniques, and behaviors within an information technology environment. Mapping ATT&CK TTPs to cloud-specific security controls helps security teams understand the threats to their cloud resources and prepare for the attacks that are most likely to target their organization. A threat-informed defense strategy requires organizations to test their security control infrastructure from different angles.

BAS platforms enable security teams to realistically replicate attack techniques that are relevant to their threat environment to assess the effectiveness of their cloud security controls. Examples of simulated

(continued)

(continued)

attack scenarios might include malware, phishing and spear phishing campaigns, data exfiltration, cross-site scripting, SQL inject attacks, and more.

BAS should be an integral part of security operations, running alongside the rest of the organization's security practices, to validate security control effectiveness and improve the overall performance of the security program. With granular data generated from the automated security control validation process, the security team can take steps to address security control failures and identify areas that require improvement.

Security teams can leverage the information they derive from the CTID cloud mapping initiative (discussed in Chapter 1) to build testing scenarios that help them evaluate and monitor the ongoing effectiveness of the security controls built into their cloud platforms. Because both the threat landscape and public cloud platforms themselves are constantly evolving, periodic testing is no longer adequate. Continuous testing is needed to ensure security controls remain effective over time.

Automation makes this possible by enabling frequent adversary emulations. An automated BAS platform enables frequent adversary emulations, ensuring the highest-priority TTPs and controls can be tested as often as necessary to achieve the objectives of the security operations center (SOC). Automation enables one-off checks, or additions to the regular testing schedule anytime conditions change, or whenever the security team learns about an emerging threat.

Organization can leverage the CTID cloud mappings for their Azure and/or Amazon Web Services (AWS) cloud environments together with a BAS platform to objectively evaluate which threats their cloud-native solutions are capable of handling and whether those solutions are correctly configured to detect, protect, and respond to specific attack scenarios.

A SOC that has developed an automated testing regime which continuously assesses the cloud platform's ability to thwart the most pervasive, highest-impact threats will finally have clarity on the effectiveness of its cloud security controls. The team can then leverage this information to identify and remedy control gaps and ensure that any upgrades and changes to the cloud platform do not result in new security gaps.

- » Cataloging threats
- » Enabling continuous detection and response capabilities

Chapter 3

Leveraging ATT&CK at Microsoft and Google

The Center for Threat-Informed Defense (the Center) benefits from the insights of some of the world's best cybersecurity practitioners, who bring diverse perspectives and experiences to the Center's applied research. Microsoft and Google participants in the Center's cloud mappings project agree that MITRE ATT&CK can help cloud service providers (CSPs) and their customers improve their cybersecurity effectiveness.

To help you further the practice of threat-informed defense and improve cybersecurity effectiveness in your organization, in this chapter, we explore how CSPs benefit from the cloud and MITRE ATT&CK mappings with insights from two leading technologists at Microsoft and Google.

Enriching Threat Intelligence and Security Controls at Microsoft

Madeline Carmichael is the Senior Threat Intelligence Librarian at Microsoft's Threat Intelligence Center (MSTIC) and a former cyber analyst in the Communications Security Establishment (CSE), one of Canada's key security and intelligence organizations.

With a background in library science, Madeline recognizes the value of cataloging data to provide context and organize threat intelligence into actionable information. In her work at MSTIC, she adds the ATT&CK framework as a layer on top of the threat intelligence produced by her team to improve understanding through a common vocabulary.

Threat analysts are constantly tracking threat actors and what they're doing. Some of the adversary behaviors that Madeline's team identifies are quite novel, and some may not translate immediately to existing ATT&CK techniques or something that a defender can do anything about. But as understanding of new behaviors grows, new ATT&CK techniques are added to help say what you know about threat actors and what they're doing. If you reference an ATT&CK tactic or sub-technique identification number, the meaning isn't confusing because it provides clarity about the threat behavior, which improves the team's shared understanding of the threat. You also don't have confusion over different preferences for wording; everyone in the organization is reading the same thing, and that consistency helps set a baseline for defensive operations.



REMEMBER

ATT&CK has been established as a common vocabulary across sectors and companies because organizations need to be able to discuss threats in a clear, concise, and consistent manner. This common vocabulary matters, especially for the cloud mapping project, which gives teams additional context for thinking about security controls. You can talk about what an attack is doing, mapped to ATT&CK, and speak about how the security controls are mapped on top of each other to mitigate the attack.

ATT&CK adds another layer for defenders and customers to use so everyone is speaking clearly about native security controls and what tactics, techniques, and procedures (TTPs) you want them to protect against.

Madeline sees a significant increase in community support for the ATT&CK framework and its use and says that it's closing some gaps in defensive performance. The more you learn about a threat actors' techniques and behaviors, the more that confirms their prevalence. The threat intelligence community is constantly finding new tactics and techniques and cataloging them into ATT&CK.

As an observer of the defensive community (operating herself from the background of threat intelligence and data management), Madeline has seen the number of techniques and sub-techniques included in the framework increase and more security products evolve to be mapped against it. As more tactics get cataloged, there's an impetus for detection security products to provide more coverage against tactics. New detections are introduced, and teams capture more visibility and more context because they detect different things. Over time, more and more products collect data about TTPs observed in ATT&CK and in the wild.

Transforming Cloud Security at Google

Iman Ghanizada is the Global Security Solutions Manager at Google and the founder of Google's Autonomic Security Operations. He and his team are modernizing multi-cloud, Google-scale, threat-management capabilities for customers.

Iman sees a transformation unfolding in the way that cloud companies build, which has major implications for how they think about threats, including for adopting MITRE ATT&CK. Iman views cloud security from two sides. On one side, you have the build components of infrastructure, DevOps, and related areas. On the other side, you have the attackers' world.

On both sides, Iman sees a movement toward standardization. He sees a standardization in the potential ways that adversaries can conduct their attacks. Analytics will be standardized on both sides, including for ATT&CK TTPs (and attack coverage) and cloud workloads. This trend will impact how CSPs and enterprise customers build proactive threat engineering into their cloud defensive capabilities.

Practically, for Google Cloud Platform (GCP), defenders want to understand how GCP maps to ATT&CK because it helps detection and response teams do their work. Prior to this alignment, everyone was taking a do-it-yourself (DIY) approach to mapping threat behaviors to the security controls available in GCP. Iman thinks that having the GCP mapping on the Enterprise Attack Navigator will uplift GCP's entire customer base and help them leverage a lot of the research Google has done with the Center. For their customers doing analytics, it makes the job easier.

For CSPs, Iman sees the need for a continuous detection and continuous response capability within the cloud, which heavily emphasizes the concept of *purple teaming* and detection engineering. This continuous cycle consists of looking at the threat, building data analysis around the threat, and then orchestrating response capabilities to mitigate the threat. Through this process, analytics can be standardized to streamline the process of threat and defensive management.

Cloud security controls align to ATT&CK in many ways:

- » The product team manages pre-built detections that provide high value analytical capabilities
- » They have a frame of reference for customers to look at GCP's capabilities, and they augment their workforce.
- » There's an open-source analytics process, known as Community Security Analytics, that the Center is working on with Google.



TIP

The benefits of purple teaming and continuous detection and continuous response can be transformative. Historically, security operations teams have focused on alerts. For modern security operations teams, the practice of threat-informed defense changes how you think about your work. Building and stitching the story together — mapping cloud controls to ATT&CK — helps you understand how to plan for the threat. As long as you can map appropriate controls to the threat in advance (which is a proactive approach) rather than the alert (which is a reactive approach), defenders can build stronger analytics and models for a better defense.

The purpose of purple teaming here is two-fold:

- » To validate the quality of the cases that you've built, from the point of data collection to response
- » To then plan your defensive playbooks in response

From there, true actionable insights can drive down alert fatigue because you're planning your responses against threats that you already understand. You can derive true value including understanding the threat to improve your defensive playbook, and providing trusted insights to your business teams to improve the quality of your controls. This is the transformative factor that Google uses to make sure that it's proactively managing threats. It's the alignment of threat and risk management together.

IN THIS CHAPTER

- » Understanding who does what in the shared responsibility model
- » Knowing your data and specific use cases
- » Taking control of cloud-native security controls
- » Evolving your perimeter-based defense strategies
- » Securing your identities, data, and datastores
- » Being a good cloud citizen

Chapter 4

Ten Lessons for Cloud Security Operations

This chapter gives you ten helpful tips to maximize the effectiveness of your cloud security operations.

Know Your (Shared) Responsibilities

Unlike your on-premises environment, where you're responsible for the end-to-end security of everything in your data center and on your network, in the public cloud some of your security responsibilities are *shared* with your cloud service provider (CSP). Although each CSP publishes its own version of the shared responsibility model, the responsibilities across different cloud service types — infrastructure as a service (IaaS), platform as

a service (PaaS), and software as a service (SaaS) — are fairly consistent among the different public cloud platforms. Ensure you understand your security responsibilities for all the different resources and service types in each of your public cloud environments, including any nuances between them.



TIP

Check out Chapter 1 for more information about the shared responsibility model.

Understand Your Data and Use Case

Everything starts with knowing what's important in your cloud environment and why you need to protect it. Armed with this understanding, you can begin to figure out how your data is used and how it could potentially be exploited, compromised, or stolen.



REMEMBER

Although you no doubt have many different resources in your public cloud environment, ultimately, it's your data that's most valuable — to both your organization and to threat actors. Protecting your organization's data in the cloud is imperative.

Know Your Terrain — Cloud Architecture Can Be Strange and Confusing

The public cloud can be a complex and confusing environment. Different cloud providers offer different services and have different names for many of the same services. And the only thing constant about the cloud is change. Your security team has a duty to get to know your cloud architecture and stay on top of changes made by both your organization and your CSP. You also need to understand all the different cloud resources and services that process and move your data around in this strange new world.



REMEMBER

If you don't know your own “backyard,” you don't have a “home field” advantage when it comes to protecting your cloud environment from adversaries.

Know Your Controls — Cloud Security Is a Little Odd

In much the same way that cloud architecture can be strange and confusing (see the preceding section), cloud security can be a bit, well, different. After you have a grasp on your cloud architecture, look at the cloud controls available to you, including what you do and don't control in the cloud (check out Chapter 1 for more information).



REMEMBER

Knowing your terrain helps you understand the different attack vectors in the cloud, which will perhaps necessitate different controls in the cloud than what you may have used on-premises.

Drain the Moat — Perimeter-Based Models Are Largely Obsolete

With the proliferation of cloud, remote work (including work-from-home and work-from-anywhere) and mobile computing, traditional perimeter-based “castle-and-moat” network security architectures have largely been relegated to the Dark Ages. Organizations need to focus on securing their users, devices, applications, and data wherever they're located.

Treat Identity As the New Data

Identity has become the new perimeter that adversaries target to gain access to a victim network. Credential theft is now a key attack objective for adversaries. The ATT&CK framework lists 15 techniques and 40 sub-techniques under the “Credential Access” tactic.



TIP

Enforce strong authentication methods to protect your cloud environment including multi-factor authentication (MFA), conditional access (CA), passwordless authentication, and others.

Treat Data As the New Identity

Authorization and access grants are increasingly based on a series of data points, not simply a set of credentials. Many context variables determine whether you are who (or what) you say you are and whether you should be able to do the things you're doing. This is the essence of a zero trust strategy: knowing who (or what) is in your cloud environment and what they (or it) are doing.

Address Datastore Considerations

Having established that data is the thing you most need to protect in the cloud, it's important to address how that data is stored in the cloud. Amazon Simple Storage Service (S3) and Azure Storage Accounts offer fast, convenient, scalable storage for your organization's data. But it's important to remember how quickly bad things can happen if these services aren't properly secured. Restricting internet access, encrypting data at rest, and securing key management are just a few examples of the many security controls you need to evaluate for your cloud datastores.

Be Neighborly in Multi-Tenant Environments

Multi-tenancy — the characteristic of being able to dynamically assign and reassign different physical and virtual cloud resources — is a core requirement of the public cloud. Remember that you aren't alone in the public cloud. CSPs go to great lengths to ensure their customers' data and resources are kept separate and secure — their business model depends on it — but this doesn't preclude the possibility of a threat, such as a breach or an outage, negatively impacting numerous customers. Just as tenants in an apartment complex share common areas and services, so too do tenants in the public cloud.

“There Is No Cloud” — It’s Just Someone Else’s Datacenter

Although there is a lot of complexity in cloud environments, don’t be intimidated. At the end of the day, remember it’s nothing more than a (very large) datacenter owned by someone else (like Microsoft, Amazon, or Google).

Implement ATT&CK for cloud cybersecurity

How can you best defend your data in the cloud? After decades of growth in internet access, today the world is transitioning to cloud technologies to store data, create content, and innovate. But we don't yet have a clear sense of best practices for cloud security. What should be done? Security teams can get ahead by focusing on known threats, prioritizing data to defend, and mapping known threat behaviors to security controls in the cloud. The way to begin your cloud security journey is with MITRE ATT&CK®.

Inside...

- Understand ATT&CK and cybersecurity
- Conceptualize cloud security
- Focus security teams on known threats
- Conduct purple team operations
- Make ATT&CK operational in the cloud
- Learn from key cloud leaders
- Identify novel methods of cloud security

ATTACKIQ

Go to **Dummies.com™**
for videos, step-by-step photos,
how-to articles, or to shop!

ISBN: 978-1-119-87546-8

Not For Resale

for
dummies
A Wiley Brand



WILEY END USER LICENSE AGREEMENT

Go to www.wiley.com/go/eula to access Wiley's ebook EULA.